

Corporate GDPR & Security Compliance Standard

Section 1: Data Protection & Access Control Guidelines

Paragraph 1: All customer personally identifiable information (PII) must be encrypted both in transit using TLS 1.3 and at rest using AES-256 bits keys. Access keys must be rotated every 90 days without exception.

Paragraph 2: Authentication controls must require multi-factor verification (MFA) for all administrative and auditor privileges. Passwords must consist of a minimum of 14 characters, combining alphanumeric and special marks.

Section 2: Security Breach Notification Timelines

Paragraph 1: In the event of a confirmed security incident or unauthorized access to corporate database tables containing PII, compliance operations must trigger notification alerts to regulatory authorities.

Paragraph 2: All vendor service agreements must mandate security breach notification reporting to the compliance board within seventy-two (72) hours of incident identification. Failure to notify within this timeframe constitutes a material breach.

Section 3: PII Data Retention and Erasure Rules

Paragraph 1: Personally identifiable information must only be retained for as long as necessary to fulfill business transactions. The maximum retention limit for inactive user profiles is set at two (2) years.

Paragraph 2: Upon service termination, all customer data must be purged or anonymized within thirty (30) days from all primary drives and backup systems. Proof of erasure certification must be delivered.